

SAP GRC Access Control

Guia pratico de governanca, riscos, acessos e segregacao de funcoes

Este material apresenta o papel do SAP GRC Access Control dentro de um programa de Seguranca SAP, com foco em governanca de acessos, analise de riscos, aprovacao, ciclo de vida de roles e acessos emergenciais.

1. Para que serve o SAP GRC Access Control

- Centralizar a governanca de acessos SAP e apoiar controles de risco.
- Identificar conflitos de Segregacao de Funcoes (SoD) e acessos criticos.
- Controlar solicitacoes, aprovacoes e provisionamento de acessos.
- Governar Business Roles e o ciclo de vida das autorizacoes.
- Controlar acessos emergenciais e registrar evidencias para auditoria.

2. ARA - Access Risk Analysis

- Executa analises de risco por usuario, role, perfil e cenarios simulados.
- Ajuda a identificar conflitos SoD e funcoes/acoes criticas.
- Permite analisar o risco antes de conceder acesso e durante revisoes periodicas.
- O resultado deve ser avaliado junto ao contexto de negocio, owner do risco e controles mitigadores.

3. ARM - Access Request Management

- Organiza o processo de solicitacao de acesso.
- Permite workflows de aprovacao com regras, agentes e estagios.
- Pode apoiar provisioning e remocao de acessos conforme o desenho da integracao.
- Mantem rastreabilidade de quem solicitou, aprovou e executou a mudanca.

4. BRM - Business Role Management

- Apoia a governanca do ciclo de vida das Business Roles.
- Facilita padronizacao, ownership, aprovacao e documentacao de roles.
- Ajuda a reduzir criacao descontrolada de perfis e melhora a qualidade do Role Design.

5. EAM - Emergency Access Management

- Controla acessos privilegiados temporarios por meio de Firefighter.
- Registra sessoes e atividades para revisao posterior.
- Permite atribuir responsaveis, owners e controllers ao processo emergencial.
- Nao substitui um bom Role Design; deve ser usado para necessidade excepcional e controlada.

6. MSMP e Rule Set

- MSMP estrutura workflows, caminhos, estagios, agentes e regras de decisao.
- O Rule Set representa riscos, funcoes, acoes e permissoes usadas pela analise de risco.
- Um Rule Set mal mantido pode gerar falsos positivos, falsos negativos e decisoes erradas.
- Mudancas devem ter governanca, documentacao, teste e aprovacao antes de chegar a producao.

7. SoD - Segregacao de Funcoes

- SoD busca evitar que uma unica pessoa concentre etapas incompatíveis de um processo.
- Exemplo: criar fornecedor e executar pagamento pode representar risco financeiro quando combinado no mesmo usuario.
- Nem todo conflito significa fraude: o risco deve ser analisado, removido quando possivel ou mitigado com controle compensatorio formal.

8. Fluxo recomendado de governanca

- Solicitar acesso -> analisar risco -> aprovar -> provisionar -> monitorar -> recertificar -> remover quando nao for mais necessario.
- Para riscos: detectar -> avaliar impacto -> identificar owner -> decidir remediacao ou mitigacao -> coletar evidencia -> revisar periodicamente.

9. Boas praticas

- Aplicar principio do menor privilegio.
- Manter owners de risco e de roles definidos.
- Executar recertificacoes periodicas.
- Evitar mitigacoes permanentes sem revisao.
- Registrar evidencias de aprovacao, alteracao e revisao.
- Integrar GRC com a estrategia de IAM, SAP Security, BTP, SIEM e auditoria quando fizer sentido.

10. Mapa rapido dos componentes

Componente	Objetivo principal
ARA	Analise de riscos, SoD e acessos criticos
ARM	Solicitacao e workflow de acessos
BRM	Governanca de Business Roles
EAM	Acesso emergencial / Firefighter
MSMP	Motor de workflow e aprovacao
Rule Set	Modelo de riscos, funcoes, acoes e permissoes

Material educacional do SAP Security Eixo. A configuracao real de SAP GRC deve considerar a versao, arquitetura, processos, Rule Set e requisitos de controle de cada organizacao.